

FAICP 2025–2026: Indicadores de Ciberseguridad para Sistemas de IA

Tendencias Internacionales, Métricas Territoriales por CCAA y Perspectiva Comparativa Mundial

"La inteligencia artificial ha cometido el imperdonable error de convertirse en infraestructura crítica antes de que tuviéramos la infraestructura normativa para protegerla. El FAICP es, en cierta medida, la disciplina que se impone a posteriori con la esperanza de que no sea demasiado tarde."

Tipo: Informe de Investigación Integral | **Versión:** 1.0 — Abril 2026

Marco principal: NIST IR 8596 · AI RMF 1.0 · EU AI Act · ENS · NIS2 · ISO/IEC 42001 · OWASP LLM Top 10 · MITRE ATLAS

RESUMEN EJECUTIVO

El año 2025 marcó un punto de inflexión para la ciberseguridad de los sistemas de inteligencia artificial. El NIST publicó el borrador preliminar del **Cyber AI Profile (NIST IR 8596)** el 16 de diciembre de 2025, el primer marco que traduce de forma sistemática las seis funciones del CSF 2.0 en indicadores específicos para entornos donde la IA es tanto activo estratégico como vector de amenaza.

Simultáneamente, la Agencia Española de Supervisión de la Inteligencia Artificial (AESIA) publicó **16 guías prácticas de cumplimiento del EU AI Act** —las primeras de su tipo en Europa—, y el Gobierno aprobó **1.157 millones de euros** para ciberseguridad, el mayor esfuerzo histórico en la materia.[¹][²][³][⁴][⁵][⁶]

Sin embargo, estos avances normativos y presupuestarios contrastan con una realidad de madurez operativa que cabría caracterizar como **transición crítica**: el Cisco Cybersecurity Readiness Index 2025 sitúa a España con apenas un **2% de empresas en nivel "Mature"** en preparación general para la era IA, y solo el **7% ha alcanzado madurez en "AI Fortification"**, lo que refleja exactamente esa asimetría entre ambición regulatoria e implementación práctica. INCIBE, por su parte, registró **122.223 incidentes en 2025**, un 26% más que el año anterior, de los cuales el 80% de los ataques de ingeniería social a nivel europeo ya incorporaban componentes de IA generativa.[⁷][⁸][⁹][¹⁰][¹¹][¹²]

PARTE I — EL MARCO FAICP: ESTADO DEL ARTE 2025–2026

1.1. El NIST IR 8596: El Documento Fundacional

El **NIST Interagency Report 8596**, titulado *Cybersecurity Framework Profile for Artificial Intelligence* y publicado como borrador inicial en diciembre de 2025, es el resultado de más de un año de colaboración con más de 6.500 contribuyentes procedentes de gobierno, academia e industria. El documento extiende formalmente el CSF 2.0 al dominio de la IA, reconociendo que la IA no es simplemente una carga de trabajo más, sino que **introduce comportamiento no determinista, caminos de decisión opacos y clases de ataque completamente nuevas** que los controles de seguridad tradicionales no fueron diseñados para manejar.[¹³][¹⁴][¹⁵][¹]

La arquitectura del IR 8596 se organiza en torno a tres **focus areas** o dimensiones de riesgo:[^3][^15]

- **SECURE (Asegurar)**: Los riesgos introducidos por la IA en la organización. Superficies de ataque nuevas: el modelo puede ser envenenado, los datos de entrenamiento contaminados, la cadena de suministro comprometida.
- **DEFEND (Defender)**: Las oportunidades de usar la IA para fortalecer la postura defensiva. Detección de amenazas, correlación de alertas y automatización de respuestas a velocidad de máquina.
- **THWART (Contrarrestar)**: La resistencia al uso adversarial de la IA por parte de atacantes. Phishing hiperpersonalizado, malware polimórfico, deepfakes, explotación automatizada.

Un análisis crítico relevante señala que, aunque el perfil sienta una base sólida, presenta lagunas específicas en el tratamiento de la **IA agéntica** —sistemas de IA con capacidad de acción autónoma en el mundo real— que OWASP complementa de forma más granular.[^15]

1.2. Los Indicadores Tier 1 del Cyber AI Profile

El IR 8596 identifica indicadores de alta prioridad ("Tier 1") para cada una de las seis funciones del CSF 2.0. En términos operativos, estos son los indicadores sobre los que toda organización debería actuar en primer lugar, independientemente de su nivel de madurez de partida:[^14][^1]

Código	Función	Indicador	Dimensión de Riesgo
GV.OC-04	GOBERNAR	Política formal de ciberseguridad para IA	SECURE
GV.OC-05	GOBERNAR	Dependencias de infraestructura crítica introducidas por IA	SECURE
GV.RR-04	GOBERNAR	Riesgos de IA adversarial integrados en formación de RRHH	THWART
GV.SC-07	GOBERNAR	Evaluación sistemática de riesgos de proveedores de IA	SECURE
ID.AM-07	IDENTIFICAR	Inventario de sistemas de IA con datos de entrenamiento (AI-BOM)	SECURE
PR.AA-01	PROTEGER	Gestión de identidades específica para sistemas de IA	SECURE
PR.AA-05	PROTEGER	Menor privilegio para sistemas de IA autónomos	SECURE
DE.CM-06	DETECTAR	Monitorización de comunicaciones hacia/desde APIs de IA	DEFEND
DE.CM-09	DETECTAR	Monitorización en tiempo de ejecución de sistemas de IA	DEFEND
RS.MA-01	RESPONDER	Playbooks de respuesta específicos a incidentes de IA	THWART
RC.RP-02	RECUPERAR	Planes de recuperación con rollback de modelos de IA	SECURE

Las implicaciones en términos de gestión son significativas: la velocidad y escala de los ataques potenciados por IA obligan a replantear los tiempos de respuesta. IBM documenta que las actividades de escaneo automatizado ya alcanzan **36.000 escaneos por segundo**, y los incidentes de BEC (Business Email Compromise) asistidos por IA crecieron un 37% según el FBI IC3 2025. Los playbooks diseñados para respuesta humana son, literalmente, insuficientes.^[15]

1.3. NIST AI RMF y ISO/IEC 42001: Los Marcos Complementarios

El **NIST AI RMF 1.0 (AI 100-1)** aporta la dimensión de confiabilidad del sistema de IA, con sus siete características de la IA fiable: validez, seguridad, privacidad, transparencia, equidad, explicabilidad y robustez. Sus funciones GOVERN, MAP, MEASURE y MANAGE se articulan de forma paralela —no

idéntica— a las del CSF 2.0, lo que permite alinear la gestión de riesgos de IA con la gestión de riesgos de ciberseguridad sin duplicar estructuras.^[1]

La norma **ISO/IEC 42001:2023**, primer estándar internacional de sistema de gestión para organizaciones que desarrollan u operan sistemas de IA, establece los requisitos para un *Artificial Intelligence Management System* (AIMS). Su estructura de cláusulas 4-10 es completamente paralela a ISO 27001:2022, facilitando la integración con los SGSI existentes. El Anexo B.7 aborda explícitamente la ciberseguridad específica para sistemas de IA, incluyendo el control B.7.4 sobre ataques adversariales.

1.4. OWASP LLM Top 10 (2025): La Taxonomía Técnica Operativa

El OWASP Top 10 para *Large Language Model Applications*, en su versión 2025 publicada el 18 de noviembre de 2024, es la referencia técnica más granular y más citada en entornos de desarrollo y seguridad para sistemas LLM. Las actualizaciones más relevantes respecto a la versión anterior son la incorporación de dos nuevas categorías —**System Prompt Leakage** y **Vector and Embedding Weaknesses**— y la re-priorización de toda la lista:^{[16][17][18][19]}

Ranking	Vulnerabilidad	Vectores de Explotación Representativos
LLM01	Prompt Injection	Directa (usuario malicioso) e indirecta (documentos, páginas web que el agente consulta) [^16]
LLM02	Sensitive Information Disclosure	Extracción de PII, secretos del system prompt, datos de entrenamiento [^18]
LLM03	Supply Chain	Backdoors en modelos de repositorios públicos, dependencias comprometidas [^18]
LLM04	Data and Model Poisoning	Manipulación de datos de entrenamiento o fine-tuning para sesgar comportamiento [^18]
LLM05	Improper Output Handling	XSS, SSRF, ejecución de código via outputs no sanitizados [^19]
LLM06	Excessive Agency	Agentes con capacidad de acción excesiva no acotada [^16]
LLM07	System Prompt Leakage	Revelación de instrucciones confidenciales del system prompt [^17]
LLM08	Vector and Embedding Weaknesses	Ataques a sistemas RAG y bases de datos vectoriales [^16]
LLM09	Misinformation	Decisiones erróneas basadas en outputs del modelo [^20]
LLM10	Unbounded Consumption	Denegación de servicio, costes descontrolados por consumo excesivo [^19]

La posición de LLM01 (Prompt Injection) como amenaza principal es especialmente relevante para organizaciones con sistemas de IA integrados en flujos de trabajo internos, ya que la inyección indirecta —mediante documentos que el agente procesa— no requiere acceso directo al sistema y es significativamente más difícil de detectar.

1.5. MITRE ATLAS: El ATT&CK de la Inteligencia Artificial Adversarial

MITRE ATLAS (*Adversarial Threat Landscape for Artificial-Intelligence Systems*) es el equivalente funcional al MITRE ATT&CK para el dominio de los ataques a sistemas de IA. La actualización de octubre de 2025, desarrollada en colaboración con Zenity Labs, introdujo 14 nuevas técnicas y sub-técnicas específicas para **IA agéntica**, incluyendo:[^21][^22]

- AI Agent Context Poisoning: Manipulación de la memoria o el contexto del agente para alterar su comportamiento
- RAG Credential Harvesting: Extracción de credenciales almacenadas en bases de datos vectoriales
- AI Agent Tool Invocation: Abuso de herramientas externas accesibles por el agente
- Discover AI Agent Configuration: Reconocimiento de la arquitectura interna de agentes mediante consultas

La versión de datos v5.0.0, lanzada simultáneamente, contiene **1 matriz, 15 tácticas, 66 técnicas y 46 sub-técnicas**, e introduce el campo "Technique Maturity" que distingue entre técnicas teóricas, demostradas en entornos controlados y verificadas en incidentes reales.^[23]^[21]

Una actualización posterior (v5.5.0, marzo 2026) añadió técnicas adicionales sobre agentes IA, incluyendo *AI Agent Tool Poisoning*, *AI Supply Chain Rug Pull* y *Cost Harvesting: Agentic Resource Consumption*, lo que muestra la rapidez con que el panorama de amenazas agénticas está evolucionando.^[24]

PARTE II — INDICADORES Y MÉTRICAS FAICP: TAXONOMÍA COMPLETA

2.1. El Índice de Gobernanza y Madurez FAICP (IGM-FAICP)

El **IGM-FAICP** es el indicador compuesto que sintetiza la postura de ciberseguridad IA de una organización en una puntuación en escala 1-5. Su fórmula ponderada es:

$$\begin{aligned} &[\\ \text{IGM} &= \sum_{f=1}^6 w_f \cdot \bar{M}_f \\ &] \end{aligned}$$

Donde (w_f) son los pesos asignados a cada función y ($\bar{M}_f$) es la media aritmética de los indicadores de madurez de esa función.

Pesos por función:

Función	Código	Peso (w)	Justificación
Gobernar	GV	0.20	Habilitadora de todas las demás funciones
Identificar	ID	0.20	Prerequisito lógico para proteger lo que se conoce
Proteger	PR	0.25	Mayor densidad de controles operativos
Detectar	DE	0.15	Crítica pero parcialmente automatizable
Responder	RS	0.10	Alta dependencia de las capacidades anteriores
Recuperar	RC	0.10	Complementaria a Responder

Interpretación del IGM:

Rango IGM	Nivel	Color	Recomendación Inmediata
1.0 - 1.5	Crítico		Intervención urgente; riesgo regulatorio elevado
1.5 - 2.5	Emergente		Plan de mejora prioritario en GV e ID
2.5 - 3.5	Desarrollado		Consolidación y extensión de controles existentes
3.5 - 4.5	Avanzado		Optimización, automatización y mejora continua
4.5 - 5.0	Líder		Referente sectorial; compartir prácticas

2.2. Métricas por Función: Taxonomía Operativa

Función GOBERNAR — 6 Indicadores Primarios

Código	Indicador	Marco Fuente	Métrica
IGM-GV-01	Política formal de ciberseguridad para IA	NIST IR 8596 GV.OC-04[^1]	Escala 1-5 + checklist de elementos
IGM-GV-02	Mapa de dependencias de infraestructura IA	NIST IR 8596 GV.OC-05[^1]	Escala 1-5 + inventario de proveedores
IGM-GV-03	Riesgos IA adversarial en formación RRHH	NIST IR 8596 GV.RR-04[^1]	Escala 1-5 + cobertura temática
IGM-GV-04	Evaluación sistemática de proveedores IA	NIST IR 8596 GV.SC-07[^1]	Escala 1-5 + periodicidad
IGM-GV-05	Función de gobernanza de IA (comité/rol)	AI RMF GOVERN 1.1[^1]	Binario + calidad (1-5)
IGM-GV-06	Registro y clasificación EU AI Act	EU AI Act Art. 49[^25]	Escala 1-5 + completitud del registro

Función IDENTIFICAR — 5 Indicadores Primarios

Código	Indicador	Marco Fuente	Métrica
IGM-ID-01	AI-BOM: Inventario completo de sistemas de IA	NIST IR 8596 ID.AM-07[^1]	Escala 1-5 + exhaustividad del inventario
IGM-ID-02	Evaluación de vulnerabilidades específicas IA	OWASP LLM Top 10[^19][^16]	Escala 1-5 + cobertura LLM01-LLM10
IGM-ID-03	Consumo de inteligencia de amenazas IA adversarial	MITRE ATLAS[^23][^21]	Escala 1-5 + fuentes CTI consumidas
IGM-ID-04	Modelado de velocidad de ataques IA en gestión de riesgos	NIST IR 8596 ID.RA-04[^14]	Ordinal 4 niveles
IGM-ID-05	Análisis de riesgos de cadena de suministro IA	NIST IR 8596 ID.SC-02; OWASP LLM03[^19]	Escala 1-5

Función PROTEGER — 6 Indicadores Primarios

Código	Indicador	Marco Fuente	Métrica
IGM-PR-01	IAM específico para sistemas y agentes de IA	NIST IR 8596 PR.AA-01[^1]	Escala 1-5 + controles implementados
IGM-PR-02	Menor privilegio en agentes IA autónomos	NIST IR 8596 PR.AA-05; OWASP LLM06[^19]	Escala 1-5
IGM-PR-03	Cobertura y frecuencia de formación en amenazas IA	EU AI Act Art. 4 (Alfabetización IA) [^25]	Ordinal 5 niveles
IGM-PR-04	Protección de datos de entrenamiento e inferencia	EU AI Act Art. 10; OWASP LLM02[^25] [^19]	Escala 1-5
IGM-PR-05	Control de versiones y gestión MLOps de modelos	NIST IR 8596 PR.PS-01[^1]	Escala 1-5
IGM-PR-06	Evaluación y control de agencia excesiva (LLM06)	OWASP LLM06; EU AI Act Art. 14[^19][^25]	Ordinal 5 categorías

Función DETECTAR — 5 Indicadores Primarios

Código	Indicador	Marco Fuente	Métrica
IGM-DE-01	Monitorización de APIs de IA externas	NIST IR 8596 DE.CM-06; OWASP LLM10[^1] [^19]	Escala 1-5
IGM-DE-02	Monitorización en tiempo de ejecución de sistemas IA	NIST IR 8596 DE.CM-09[^1]	Escala 1-5
IGM-DE-03	Frecuencia y método de evaluación de model drift	EU AI Act Art. 72.1; AI RMF MEASURE 2.6[^25]	Ordinal 6 niveles
IGM-DE-04	Capacidades del SOC para amenazas IA adversariales	MITRE ATLAS (tácticas múltiples)[^21][^26]	Escala 1-5
IGM-DE-05	Controles de detección de prompt injection	OWASP LLM01; NIST IR 8596 DE.CM-03[^19] [^16]	Escala 1-5

Función RESPONDER — 4 Indicadores Primarios

Código	Indicador	Marco Fuente	Métrica
IGM-RS-01	Playbooks de respuesta específicos para IA	NIST IR 8596 RS.MA-01[^1]	Escala 1-5 + escenarios cubiertos
IGM-RS-02	Capacidad de análisis forense de sistemas de IA	NIST IR 8596 RS.AN-03[^1]	Ordinal 5 categorías
IGM-RS-03	Conocimiento y aplicación plazos notificación IA	EU AI Act Art. 73; NIS2 Art. 23[^25]	Ordinal 5 categorías
IGM-RS-04	MTTR-AI: Tiempo medio de respuesta a incidentes IA	NIST IR 8596 RS.AN-03[^1]	Temporal 7 rangos

Los plazos de notificación son especialmente relevantes: el EU AI Act Art. 73 establece 15 días hábiles para notificación de incidentes graves a AESIA para sistemas de alto riesgo; NIS2 Art. 23 exige notificación inicial en 24 horas. El desconocimiento de estos plazos es en sí mismo un indicador de madurez deficiente.[^25][^27]

Función RECUPERAR — 3 Indicadores Primarios

Código	Indicador	Marco Fuente	Métrica
IGM-RC-01	Planes de recuperación con rollback de modelos	NIST IR 8596 RC.RP-02[^1]	Escala 1-5
IGM-RC-02	RTO-AI: Tiempo Objetivo de Recuperación para IA	NIS2 Art. 21.2.c; DORA Art. 24[^25]	Temporal 6 rangos
IGM-RC-03	Revisión de decisiones del sistema comprometido	EU AI Act Art. 72.1; NIST IR 8596 RC.RP-03[^1][^25]	Ordinal 5 categorías

La dimensión de IGM-RC-03 —revisión de decisiones tomadas por el sistema comprometido durante el período de incidente— es probablemente la más novedosa y la menos cubierta por marcos convencionales de recuperación ante desastres. Su relevancia aumenta exponencialmente en sistemas de IA con impacto en personas: crédito, empleo, sanidad, justicia.

2.3. Indicadores de Cumplimiento Normativo (Sección 8)

Código	Marco	Indicador	Sanciones Máximas
IGM-CUM-01	EU AI Act	Estadio de implementación	Hasta 30M€ o 6% volumen global[^25]
IGM-CUM-02	ENS RD 311/2022	Nivel de certificación (AAPP)	Responsabilidad disciplinaria
IGM-CUM-03	NIS2	Estado implementación Art. 21 (10 medidas)	Hasta 10M€ o 2% facturación global[^25]
IGM-CUM-04	ISO/IEC 42001	Adopción como marco referencia	Voluntario (sin sanción directa)
IGM-CUM-05	RGPD + EU AI Act Art. 27	Realización de FRIA para IA alto riesgo	Hasta 30M€ (AIA) + 20M€ (RGPD)[^25]

PARTE III — APLICACIÓN TERRITORIAL: MÉTRICAS FAICP POR CCAA

3.1. Marco de Análisis Territorial

La desagregación territorial por Comunidades Autónomas responde a una realidad estructural del sistema de ciberseguridad español: la coexistencia de capacidades de coordinación estatal (CCN-CERT, INCIBE) con responsabilidades autonómicas crecientes en materia de protección de datos, continuidad de servicios públicos y, progresivamente, supervisión de IA en las administraciones regionales. AESIA, con sede en A Coruña, opera a nivel estatal pero debe coordinarse con los organismos de supervisión digital autonómicos para los sistemas de IA de las AAPP regionales.[^28]

3.2. Índice Compuesto de Contexto Territorial (ICCT)

Para enriquecer el análisis del IGM-FAICP con el contexto donde opera cada organización, se propone un **Índice de Contexto Territorial** de cinco subcomponentes:

$$[\text{ICCT}_{\{CCAA\}} = 0.25 \cdot E_{\{TIC\}} + 0.25 \cdot C_{\{AAPP\}} + 0.20 \cdot O_{\{crit\}} + 0.15 \cdot F_{\{inv\}} + 0.15 \cdot N_{\{norm\}}]$$

Donde: ($E_{\{TIC\}}$) es el ecosistema TIC regional, ($C_{\{AAPP\}}$) la capacidad de las AAPP autonómicas, ($O_{\{crit\}}$) la presencia de operadores críticos, ($F_{\{inv\}}$) la formación e investigación, y ($N_{\{norm\}}$) la madurez del marco normativo autonómico de IA.

3.3. Iniciativas Territoriales de Referencia

CCAA	Institución	Relevancia FAICP	Marco de Referencia
Castilla y León	INCIBE (León) — Hub nacional de ciberseguridad	Centro coordinador nacional; formación y gestión de incidentes de referencia para todo el tejido empresarial	NIST, ENS, NIS2 ^[11]
País Vasco	Basque Cybersecurity Centre (BCSC)	CERT autonómico con capacidades OT/ICS consolidadas; referente industrial europeo	NIS2, ENS, ISA/IEC 62443
Cataluña	CESICAT + Estratègia d'IA de Catalunya	Agencia propia de ciberseguridad + hoja de ruta IA pública con 80+ acciones	EU AI Act, ENS
Galicia	AESIA (A Coruña) — Sede nacional	Máxima autoridad de supervisión de IA en España; sandbox regulatorio operativo ^[28] ^[2]	EU AI Act
Madrid	Madrid Digital 2027	Estrategia de digitalización segura AAPP con componente IA explícito	EU AI Act, ENS

3.4. Perfiles Territoriales Esperados

Basándose en datos disponibles de INCIBE, CCN-CERT y el Cisco CRI 2025, se identifican los siguientes **arquetipos territoriales** para el análisis de madurez FAICP:^[8]^[7]

Arquetipo	CCAA Representativas	IGM Estimado	Factores Diferenciadores
Maduro-Concentrado	Madrid, País Vasco	≥ 3.5	Alta concentración de grandes empresas tech/finanzas, ecosistema formativo potente, CERTs autonómicos con capacidades OT ^[7]
Maduro-Industrial	Cataluña, Navarra	3.0 – 3.5	Base industrial con adopción creciente de IA en OT, clústeres tecnológicos maduros
Emergente-Dinámico	C. Valenciana, Aragón	2.5 – 3.0	Digitalización acelerada pero madurez de seguridad IA en consolidación
AAPP-Centrado	Castilla y León, Andalucía	2.5 – 3.0	Foco en AAPP (sede INCIBE en León), sanidad pública y educación como sectores principales ^[11]
Transición-Asimétrica	Canarias, Extremadura, La Rioja	2.0 – 2.5	Asimetría entre AAPP coordinadas y tejido empresarial en transición digital

3.5. Brechas Territoriales Prioritarias

Las brechas de mayor relevancia para el análisis territorial, identificadas a partir de datos del INCIBE, ENISA y el Cisco CRI 2025, son:

Brecha 1 — Gobernanza IA en AAPP Locales. Los ayuntamientos de todas las CCAA muestran déficits estructurales en la adopción de marcos de gobernanza IA. La adopción del ENS como punto de referencia nacional es desigual: las CCAA con mayor presupuesto digital alcanzan niveles de certificación altos, mientras las de mayor proporción de AAPP locales pequeñas presentan brechas de hasta 1.5 puntos en el sub-índice Gobernar.

Brecha 2 — AI-BOM en Industria OT. Las CCAA industriales (País Vasco, Navarra, Cataluña) enfrentan el reto específico de inventariar componentes de IA integrados en sistemas SCADA y DCS — tarea para la que ni el ENS ni el EU AI Act ofrecen guía suficientemente detallada —, crucial dado que la ENISA ha documentado que el ransomware afecta principalmente al sector manufacturero en Europa. ^[29]

Brecha 3 — Capacidades de Detección en PYME. Las CCAA con mayor proporción de PYME (La Rioja, Extremadura, Castilla-La Mancha) presentan déficits pronunciados en los indicadores de Detección, especialmente en monitorización de model drift y capacidades SOC para amenazas IA. El dato de que un **70% de las organizaciones españolas no detecta implementaciones de IA no controladas (Shadow AI)** es especialmente pronunciado fuera de los grandes centros urbanos.[^8]

Brecha 4 — Cumplimiento EU AI Act en Sectores Emergentes. La adopción de IA en sectores como la agricultura de precisión (Extremadura, Castilla-La Mancha, Andalucía), turismo inteligente (Canarias, Baleares) y logística avanzada (C. Valenciana) está superando la capacidad de cumplimiento normativo de las empresas implicadas, especialmente en la clasificación de sistemas de alto riesgo según el Anexo III del EU AI Act.[^25]

PARTE IV — PERSPECTIVA COMPARATIVA MUNDIAL

4.1. El Cisco Cybersecurity Readiness Index 2025

El Cisco CRI 2025, basado en encuestas a 8.000 responsables de seguridad en 30 países, ofrece el benchmark más relevante para comparar la posición de España en el mapa global de ciberseguridad IA. [^30][^31]

Pilar CRI	España Mature (%)	Global Mature (%)	Gap	Interpretación
Identity Intelligence	3%	6%	-3 pp	Por debajo de la media global[^7]
Network Resilience	~20%	7%	+13 pp	Fortaleza relativa española
Machine Trustworthiness	~12%	6%	+6 pp	Sólido, por encima de media
Cloud Reinforcement	~19%	4%	+15 pp	Fortaleza relativa española
AI Fortification	7%	7%	0 pp	Exactamente en la media global[^7]
Global Mature	2%	4%	-2 pp	Por debajo de media (dato actualizado)[^8]

La paridad en AI Fortification (7% España = 7% global) es el hallazgo más significativo: España lidera en prácticamente todos los pilares convencionales de ciberseguridad, pero está exactamente en la media mundial en la dimensión específica de protección IA. Adicionalmente, el informe documenta que el **87% de las organizaciones españolas sufrió incidentes de seguridad vinculados a la IA en el último año**, y el **83% cree probable enfrentar un ciberataque grave en los próximos 12-24 meses**.[^8]

4.2. WEF Global Cybersecurity Outlook 2025

El informe del Foro Económico Mundial identifica la brecha de capacidades como el riesgo más crítico: [^32][^33]

- 66% de las organizaciones espera que la IA tenga el mayor impacto en ciberseguridad en el próximo año
- Solo 37% dispone de procesos formales para evaluar la seguridad de herramientas de IA antes de su despliegue[^32]
- 72% de los encuestados reporta incremento de riesgos cibernéticos organizacionales[^32]
- 47% cita los avances adversariales potenciados por GenAI como su principal preocupación[^32]
- 72% de los CISOs considera que el ritmo de adopción de IA supera la capacidad de sus equipos para evaluarla[^34]

Estos datos del WEF son consistentes con el Cisco CRI 2025: existe una paradoja estructural entre la conciencia sobre el riesgo (alta) y la preparación efectiva (insuficiente). La brecha no es de información sino de implementación.

4.3. ENISA Threat Landscape 2025

El ETL 2025 de ENISA, basado en 4.875 incidentes entre julio de 2024 y junio de 2025, documenta el rol de la IA como doble filo del panorama de amenazas:[^35][^29]

IA como herramienta de ataque:

- Los ataques de **phishing asistidos por IA representan más del 80%** de toda la actividad de ingeniería social observada a principios de 2025[^9][^10]
- El phishing, con un 60% de los vectores de intrusión documentados, lidera los puntos de acceso[^29]
- Los adversarios utilizan modelos jailbreakados, medios sintéticos y técnicas de *model poisoning* para mejorar su eficacia operativa[^10]

IA como objetivo de ataque:

- Primeros casos documentados de envenenamiento de modelos en producción en sectores críticos europeos
- El ransomware afecta principalmente al sector manufacturero (14.9% de las reclamaciones), sector con creciente integración de IA en procesos productivos[^29]

Para España específicamente, INCIBE reportó **122.223 incidentes en 2025** (+26% vs. 2024), con 55.411 casos de malware (incluyendo 392 de ransomware), 45.445 de fraude online y 25.133 de phishing. La tendencia acumulada confirma un crecimiento del 300% en ataques desde 2015.[^5][^36][^11][^37][^38]

4.4. Comparativa de Marcos Nacionales de Supervisión IA

País	Autoridad Principal	Marco Diferenciador	Nivel de Madurez Regulatoria
España	AESIA (desde 2024, sede A Coruña)[^28]	EU AI Act + 16 Guías Prácticas (primeras en UE)[^2] + Sandbox activo[^4]	Avanzado — líder en implementación EU AI Act
Alemania	BSI + BMAS	EU AI Act + BSI AI Security Profile	Avanzado — fuerte en sector industrial OT
Francia	ANSSI + CNIL	EU AI Act + ANSSI recommandations IA	Avanzado — referente en IA soberana
Italia	ACN + AGID	EU AI Act + Piano Nazionale per l'IA	Desarrollado — aceleración post-2023
Reino Unido	NCSC + ICO	UK AI Security Guidance NCSC 2025 (enfoque basado en principios)	Avanzado — diferenciado post-Brexit
EE.UU.	NIST + CISA	NIST AI RMF + IR 8596[^1][^3] + EO on AI Safety	Avanzado — mayor profundidad técnica
Singapur	CSA	AI Governance Framework + AI Security Testing Guidelines	Avanzado — referente Asia-Pacífico

El dato más relevante de esta comparativa es el liderazgo de España en la implementación práctica del EU AI Act: AESIA es reconocida como la autoridad de supervisión de IA más activa de Europa en 2025-2026, con máxima participación en los grupos de trabajo de la AI Office de la UE.[^28]

4.5. Vectores de Amenaza Emergentes: Prospectiva 2026-2027

Los centros de inteligencia de amenazas de referencia identifican los siguientes vectores emergentes: [^39][^24][^15]

- Ataques a agentes IA autónomos: La explotación de frameworks de agentes (LangChain, AutoGen, CrewAI) con acceso a herramientas reales mediante inyección de prompt indirecta está pasando de técnica teórica a incidente documentado[^24]
- Supply chain rug pull en IA: Modelos que funcionan correctamente durante evaluación pero muestran comportamiento malicioso en producción —técnica recién codificada en MITRE ATLAS v5.5.0[^24]
- Deepfakes en Q1 2025: Los incidentes de deepfake crecieron un 680% interanual, con Q1 2025 registrando ya más casos que todo 2024[^39]
- Ataques IA a velocidad de máquina: Los escaneos automatizados alcanzan 36.000 por segundo; los ataques BEC asistidos por IA crecieron un 37%; la IA generativa logra tasas de clic en phishing de un 54% vs. el 12% del phishing convencional[^15][^39]

PARTE V — ANÁLISIS PARA ESPAÑA: FORTALEZAS, BRECHAS Y RECOMENDACIONES

5.1. Fortalezas del Ecosistema Español

- Liderazgo en implementación EU AI Act: AESIA publicó las primeras 16 guías prácticas de cumplimiento en Europa (diciembre 2025), y España tiene la máxima participación permitida en los grupos de trabajo de la AI Office de la UE^{[2][4][28]}
- Inversión histórica en ciberseguridad: 1.157 millones de euros aprobados en mayo de 2025, con el 60.4% gestionado por el Ministerio de Defensa vía CNI-CCN^{[40][5]}
- Red de CERTs autonómicos: El modelo descentralizado (CCN-CERT + INCIBE + BCSC + CESICAT + otros) crea redundancia de capacidades y proximidad territorial
- INCIBE como hub formativo nacional: El ecosistema del INCIBE en León gestiona 122.223 incidentes anuales y la línea 017 atendió más de 142.000 consultas (+45%)^{[11][12]}
- Segundo país del mundo en número de centros de ciberseguridad por detrás de EE.UU.^[36]

5.2. Brechas Estructurales

- AI Fortification en paridad con la media global, no en liderazgo: Mientras España supera ampliamente la media global en seguridad convencional, los indicadores específicos de ciberseguridad IA están exactamente en la media^[7]
- Shadow AI sin control: El 70% de las organizaciones españolas no detecta implementaciones de IA no controladas; el 87% de empleados accede a redes corporativas desde dispositivos no gestionados^[8]
- Déficit de talento especializado: El 74% de las empresas reporta escasez de talento en ciberseguridad, un déficit que se agudiza en perfiles con conocimiento simultáneo de seguridad y sistemas de IA^[8]
- Baja confianza interna: Solo el 51% de organizaciones confía en que sus empleados comprendan completamente las amenazas relacionadas con IA^[41]
- Lentitud en AI-BOM: El inventario detallado de sistemas de IA (AI-BOM) —indicador Tier 1 del NIST IR 8596— es inexistente en la mayoría de organizaciones medianas y pequeñas^[1]

5.3. Recomendaciones por Nivel de Actuación

Para el regulador (AESIA, CCN, INCIBE):

- Desarrollar un benchmark anual de madurez FAICP por CCAA y sector, publicado como dato abierto y correlado con los incidentes gestionados por INCIBE
- Crear perfiles de cumplimiento simplificados del EU AI Act para PYME, alineados con los indicadores IGM-FAICP, siguiendo el modelo de las 16 guías ya publicadas^[2]
- Establecer requisitos mínimos de AI-BOM en los pliegos de contratación pública para sistemas de IA

Para operadores esenciales e importantes (NIS2):

- Completar el AI-BOM como primer paso urgente, integrándolo en el inventario de activos del SGSI existente
- Desarrollar playbooks de respuesta para los cinco escenarios de mayor probabilidad: phishing LLM, deepfake de fraude ejecutivo, prompt injection en sistemas internos, model drift silencioso, exfiltración

vía Shadow AI

- Incorporar indicadores IGM-FAICP en el cuadro de mando del CISO para seguimiento trimestral

Para la AAPP autonómica y local:

- Priorizar la doble certificación ENS + ISO 42001 como marco integrado para sistemas de IA en servicios públicos

- Establecer funciones de responsable de ciberseguridad IA con mandato explícito, coordinadas con AESIA y CCN

- Adoptar el FAICP como criterio de evaluación en procesos de adquisición de IA para la administración

EPÍLOGO: LA PARADOJA DEL INSTRUMENTO

Hay algo filosóficamente incómodo en medir la ciberseguridad de la inteligencia artificial con las mismas herramientas que la propia inteligencia artificial ha hecho obsoletas. Los frameworks de madurez, los índices compuestos, las escalas de Likert: toda esta arquitectura métrica fue diseñada para un mundo donde las amenazas se movían a velocidad humana y los controles podían implementarse con margen de reflexión.

El FAICP, en sus múltiples expresiones normativas —NIST IR 8596, AI RMF, EU AI Act, ISO 42001, OWASP LLM Top 10, MITRE ATLAS— tiene el mérito de reconocer esta asimetría y articular una respuesta estructurada. Pero la velocidad a la que la IA adversarial evoluciona —con 28 millones de ciberataques impulsados por IA proyectados para 2025, deepfakes creciendo un 680% y ataques BEC potenciados por IA aumentando un 37%— exige que estos marcos sean instrumentos vivos.[¹⁹][³][¹⁶][²³][²¹][²⁵][³⁹][¹][¹⁵]

España tiene, en este momento, una ventana de oportunidad singular: una autoridad regulatoria activa y reconocida internacionalmente, una red de capacidades públicas sólida y una inversión histórica comprometida. La pregunta no es si tiene los instrumentos. Es si tiene la voluntad colectiva de usarlos con la urgencia que el momento requiere.[⁵][²⁸]

El mapa que este informe contribuye a construir no es la respuesta. Es la precondition para formular las preguntas correctas.

Informe de investigación de libre distribución con atribución.

Versión 1.0 — Abril 2026

Marcos: NIST IR 8596 · AI RMF 1.0 · EU AI Act 2024/1689 · ENS RD 311/2022 · NIS2 2022/2555 · ISO/IEC 42001:2023 · OWASP LLM Top 10 2025 · MITRE ATLAS v5.0–5.5 · Cisco CRI 2025 · WEF GCO 2025 · ENISA ETL 2025 · INCIBE Informe 2025

References

1.
NIST IR 8596: Cybersecurity Framework AI Profile - Maps NIST CSF 2.0 to AI security considerations covering securing AI, AI-enabled defense, and resist...
2.
Support guides for compliance with the AI Act published - AESIA - This is a set of 16 practical guides that aim to support the implementation and compliance of the Ar...
3.
A first look at NIST's new cyber AI framework - Freeman Mathis & Gary - By: Jacob Berlinger and Jason Weiss The National Institute of Standards and Technology (NIST) recent...
4.
Practical guides for AI Act compliance - AESIA - This document provides implementation measures for providers and users of AI ... As stated in Articl...
5.
The Government approves a strengthening of Spain's ...
6.
El Gobierno aprueba un plan de 1.157 millones para reforzar la ciberseguridad - España sufrió más de 100.000 ciberataques el año pasado, uno grave cada tres días, el 70% contra adm...
7.
2025 Cisco Cybersecurity Readiness Index
8.
Apenas el 2% de las empresas españolas están preparadas para enfrentar amenazas de ciberseguridad en la era de la IA - La situación se agrava por una falta generalizada de control sobre el uso de tecnologías emergentes
9.
RST Cloud - ENISA's 2025 Threat Landscape - LinkedIn - ... data from 4875 incidents observed between July 2024 and June 2025. AI ...
10.
[PDF] ENISA THREAT LANDSCAPE 2025 - The European Union Agency for Cybersecurity, ENISA, is the Union's agency dedicated to achieving a h...

11.
INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 · Banca: 34% · Transporte: 14% · ...
12.
INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - La línea de ayuda 017 atendió más de 142.000 consultas, un 45% más que el año anterior
13.
NIST IR 8596: Cybersecurity Framework AI Profile (United States - Maps NIST CSF 2.0 to AI security considerations covering securing AI, AI-enabled defense, and resist...
14.
NIST Codifies AI Cyber Risk Response with IR 8596 - 🚨 AI has crossed the threshold from “emerging tech” to a primary cyber risk driver, and NIST just co...
15.
NIST's New Cyber AI Profile: A Solid Foundation with Critical Gaps ... - AI-powered cyberattacks increased 72% year-over-year in 2025, according to AllAboutAI analysis based...
16.
The 2025 OWASP Top 10 for LLMs | TrojAI - The new 2025 OWASP Top 10 for LLMs · LLM01: Prompt injection · LLM02: Sensitive information disclosu...
17.
The 2025 OWASP Top 10 for LLMs: What's Changed and Why It ... - The updated list includes new risks like system prompt leakage and vector embedding vulnerabilities,...
18.
OWASP Top 10 LLM Risks 2025: Key AI Security Updates | Qualys - The OWASP Top 10 for LLM Applications 2025 introduces critical updates that reflect the rapid change...
19.
[PDF] OWASP Top 10 for LLM Applications 2025 - Use Static Application Security Testing (SAST) and Dynamic and Interactive application testing (DAST...
20.
OWASP Top 10 LLM, Updated 2025: Examples and Mitigation ... - 1. Prompt Injection Attacks · 2. Sensitive Information Disclosure · 3. Supply Chain · 4. Data and Mo...

21.
Updates MITRE ATLAS™ - Michael Bargury - The September 2025 update of the ATLAS framework introduces version 4.6.0, emphasizing Agentic AI TT...
22.
MITRE ATLAS Framework 2026 - Guide to Securing AI Systems - What is the MITRE ATLAS Framework? The MITRE ATLAS (Adversarial Threat Landscape for Artificial-Inte...
23.
September 2025
24.
atlas-data/CHANGELOG.md at main · mitre-atlas/atlas-data - ATLAS tactics, techniques, and case studies data. Contribute to mitre-atlas/atlas-data development b...
25.
European AI Regulation: How to comply with the AI Act in Spain 2025 - Here's a practical guide, designed for business and technology teams in Spain, to move from theory t...
26.
 Cisco | Board Member |... - For years, defenders have built detections around what adversaries do, MITRE just reminded us it's t...
27.
New AESIA Guidelines to support compliance with the AI Act - Specialised Technical Guides (Guides 3 to 15): These guides address specific legal and technical req...
28.
AESIA consolidates its role in Europe in promoting ethical ... - Spain strengthens its leadership among European countries in its efforts to achieve responsible, hum...
29.
ENISA 2025 Threat Landscape report highlights EU faces escalating ... - The 2025 Threat Landscape report highlights that DDoS attacks were the dominant incident type, accou...
30.
2025 Cisco Cybersecurity Readiness Index - MySecurity Marketplace - Only 3% of organisations in Australia have achieved a mature level of readiness required to effectiv...

31.
2025 Cisco Cybersecurity Readiness Index - The 2025 Cisco Cybersecurity Readiness Index reveals that overall cybersecurity readiness remains fl...
32.
[PDF] Global Cybersecurity Outlook 2025 | World Economic Forum - The survey further revealed that cybercrime grew in both frequency and sophistication, marked by ran...
33.
Global Cybersecurity Outlook 2025 - The World Economic Forum - The report explores major findings and puts a spotlight on the complexity of the cybersecurity lands...
34.
Cybersecurity awareness: AI threats and cybercrime in 2025 - Cybercrime continues to rise, with cybersecurity and AI increasingly linked as both a threat and a d...
35.
ENISA Threat Landscape 2025 - European Union - This ENISA sectorial threat landscape report provides an overview of the cyber threats faced by the ...
36.
Government approves 1.1-billion-euro budget to ... - Last year around 100,000 attacks were detected and every three days there was an incident considered...
37.
INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - La línea de ayuda 017 atendió más de 142.000 consultas, un 45% más que el año anterior
38.
Los ciberincidentes gestionados por el Incibe crecen un 26% en 2025 - Los robos de información a través de ataques cibernéticos se multiplican casi por tres en el último ...
39.
AI Cyber Threat Statistics: The 2025 Landscape of AI-Powered ... - Global AI cyberattacks will surpass 28 million incidents in 2025, representing a 72% year-over-year ...
40.
Spain boosts cybersecurity with €1.2 billion investment - ACK3 - Spain invests €1.157B in cybersecurity to boost national resilience, enhance 5G security, and suppor...

41.

Cisco's 2025 Cybersecurity Readiness Index Finds Alarming ... - According to the 2025 Cybersecurity Readiness Index, only 3% of organisations in Malaysia have achie...

NIST IR 8596: Cybersecurity Framework AI Profile - Maps NIST CSF 2.0 to AI security considerations covering securing AI, AI-enabled defense, and resist...

Support guides for compliance with the AI Act published - AESIA - This is a set of 16 practical guides that aim to support the implementation and compliance of the Ar...

A first look at NIST's new cyber AI framework - Freeman Mathis & Gary - By: Jacob Berlinger and Jason Weiss The National Institute of Standards and Technology (NIST) recent...

Practical guides for AI Act compliance - AESIA - This document provides implementation measures for providers and users of AI ... As stated in Articl...

The Government approves a strengthening of Spain's ...

El Gobierno aprueba un plan de 1.157 millones para reforzar la ciberseguridad - España sufrió más de 100.000 ciberataques el año pasado, uno grave cada tres días, el 70% contra adm...

2025 Cisco Cybersecurity Readiness Index

Apenas el 2% de las empresas españolas están preparadas para enfrentar amenazas de ciberseguridad en la era de la IA - La situación se agrava por una falta generalizada de control sobre el uso de tecnologías emergentes

RST Cloud - ENISA's 2025 Threat Landscape - LinkedIn - ... data from 4875 incidents observed between July 2024 and June 2025. AI ...

[PDF] ENISA THREAT LANDSCAPE 2025 - The European Union Agency for Cybersecurity, ENISA, is the Union's agency dedicated to achieving a h...

INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 · Banca: 34% · Transporte: 14% · ...

INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - La línea de ayuda 017 atendió más de 142.000 consultas, un 45% más que el año anterior

NIST IR 8596: Cybersecurity Framework AI Profile (United States - Maps NIST CSF 2.0 to AI security considerations covering securing AI, AI-enabled defense, and resist...

NIST Codifies AI Cyber Risk Response with IR 8596 -  AI has crossed the threshold from “emerging tech” to a primary cyber risk driver, and NIST just co...

NIST's New Cyber AI Profile: A Solid Foundation with Critical Gaps ... - AI-powered cyberattacks increased 72% year-over-year in 2025, according to AllAboutAI analysis based...

The 2025 OWASP Top 10 for LLMs | TrojAI - The new 2025 OWASP Top 10 for LLMs · LLM01: Prompt injection · LLM02: Sensitive information disclosu...

The 2025 OWASP Top 10 for LLMs: What's Changed and Why It ... - The updated list includes new risks like system prompt leakage and vector embedding vulnerabilities,...

OWASP Top 10 LLM Risks 2025: Key AI Security Updates | Qualys - The OWASP Top 10 for LLM Applications 2025 introduces critical updates that reflect the rapid change...

[PDF] OWASP Top 10 for LLM Applications 2025 - Use Static Application Security Testing (SAST) and Dynamic and Interactive application testing (DAST...

OWASP Top 10 LLM, Updated 2025: Examples and Mitigation ... - 1. Prompt Injection Attacks · 2. Sensitive Information Disclosure · 3. Supply Chain · 4. Data and Mo...

Updates MITRE ATLAS™ - Michael Bargury - The September 2025 update of the ATLAS framework introduces version 4.6.0, emphasizing Agentic AI TT...

MITRE ATLAS Framework 2026 - Guide to Securing AI Systems - What is the MITRE ATLAS Framework? The MITRE ATLAS (Adversarial Threat Landscape for Artificial-Inte...

September 2025

atlas-data/CHANGELOG.md at main · mitre-atlas/atlas-data - ATLAS tactics, techniques, and case studies data. Contribute to mitre-atlas/atlas-data development b...

European AI Regulation: How to comply with the AI Act in Spain 2025 - Here's a practical guide, designed for business and technology teams in Spain, to move from theory t...

 Ciso | Board Member |... - For years, defenders have built detections around what adversaries do, MITRE just reminded us it's t...

New AESIA Guidelines to support compliance with the AI Act - Specialised Technical Guides (Guides 3 to 15): These guides address specific legal and technical req...

AESIA consolidates its role in Europe in promoting ethical ... - Spain strengthens its leadership among European countries in its efforts to achieve responsible, hum...

ENISA 2025 Threat Landscape report highlights EU faces escalating ... - The 2025 Threat Landscape report highlights that DDoS attacks were the dominant incident type, accou...

2025 Cisco Cybersecurity Readiness Index - MySecurity Marketplace - Only 3% of organisations in Australia have achieved a mature level of readiness required to effectiv...

2025 Cisco Cybersecurity Readiness Index - The 2025 Cisco Cybersecurity Readiness Index reveals that overall cybersecurity readiness remains fl...

[PDF] Global Cybersecurity Outlook 2025 | World Economic Forum - The survey further revealed that cybercrime grew in both frequency and sophistication, marked by ran...

Global Cybersecurity Outlook 2025 - The World Economic Forum - The report explores major findings and puts a spotlight on the complexity of the cybersecurity lands...

Cybersecurity awareness: AI threats and cybercrime in 2025 - Cybercrime continues to rise, with cybersecurity and AI increasingly linked as both a threat and a d...

ENISA Threat Landscape 2025 - European Union - This ENISA sectorial threat landscape report provides an overview of the cyber threats faced by the ...

Government approves 1.1-billion-euro budget to ... - Last year around 100,000 attacks were detected and every three days there was an incident considered...

INCIBE detectó más de 122.000 incidentes de ciberseguridad en 2025 - La línea de ayuda 017 atendió más de 142.000 consultas, un 45% más que el año anterior

Los ciberincidentes gestionados por el Incibe crecen un 26% en 2025 - Los robos de información a través de ataques cibernéticos se multiplican casi por tres en el último ...

AI Cyber Threat Statistics: The 2025 Landscape of AI-Powered ... - Global AI cyberattacks will surpass 28 million incidents in 2025, representing a 72% year-over-year ...

Spain boosts cybersecurity with €1.2 billion investment - ACK3 - Spain invests €1.157B in cybersecurity to boost national resilience, enhance 5G security, and suppor...

Cisco's 2025 Cybersecurity Readiness Index Finds Alarming ... - According to the 2025 Cybersecurity Readiness Index, only 3% of organisations in Malaysia have achie...